Analyse de Risque, Audit et Gestion de Crise

THEME DU PROJET

Charte de Gouvernance de la Sécurité du SI de l'Entreprise LiZbiZ

ETUDIANTE

MAKEU TENKU STELY BELVA

Matricule
24P826

Filiere
Cybersécurité et Investigation Numérique

CIN-4

ENCADREUR

Ing THIERRY MINKA

Grade
Ingénieur

Departement
Département de Génie Informatique

22 Mars 2026

2025 – 2026

TABLE DES MATIÈRES

1 Contexte et Problématique **1**

1.1 Présentation de l'entreprise LiZbiZ 1

1.2 Diagnostic de la situation actuelle 1

1.3 Périmètre de la mission 2

2 Charte de Gouvernance Proposée **3**

2.1 Structure de gouvernance cible 3

2.2 Fiche de poste du RSSI de LiZbiZ 3

2.3 Matrice RACI pour la gestion des incidents critiques 4

3 Recommandations et Plan de Mise en Oeuvre **5**

3.1 Actions prioritaires 5

3.2 Indicateurs de suivi 5

3.3 Risques résiduels et limites de la charte 6

4 Conclusion **7**

1 CONTEXTE ET PROBLÉMATIQUE

1.1 Présentation de l'entreprise LiZbiZ

LiZbiZ est une société anonyme spécialisée dans le e-commerce et la logistique automatisée. Elle affiche un chiffre d'affaires de 45 millions d'euros, compte 150 salariés et garantit une livraison en 24h grâce à sa plateforme baptisée **Smart Logistics**. Cotée en bourse depuis six mois, elle est soumise à des exigences de transparence et de conformité renforcées.

Son système d'information repose sur un ERP Odoo, une base de données PostgreSQL, un Active Directory sous Windows Server 2019, un site marchand Magento et une infrastructure IoT composée de 50 scanners RFID. Le réseau est segmenté en cinq VLANs : DMZ (VLAN 10), Applicatif (VLAN 20), Utilisateurs (VLAN 30), IoT/Logistique (VLAN 40) et Administration (VLAN 99).

1.2 Diagnostic de la situation actuelle

Attention

Suite à une croissance rapide (de 20 à 150 salariés en deux ans), la gouvernance de la sécurité n'a pas évolué en proportion. Trois problèmes structurels majeurs ont été identifiés lors de l'état des lieux initial.

Le premier problème est un **conflit d'intérêt** : la Directrice des Systèmes d'Information (Sophie M.) cumule de facto les fonctions de DSI et de RSSI. Elle valide des droits d'accès qu'elle crée elle-même, rendant tout contrôle interne inopérant.

Le second problème est un **manque de visibilité** : aucun Comité de Sécurité n'est constitué. La Direction Générale n'est pas informée de l'état réel des risques techniques.

Le troisième problème est l'absence de **RACI formel** : les processus de sécurité sont gérés de façon informelle et verbale, ce qui engendre des oublis et des erreurs répétées sur la gestion des accès.

1.3 Périmètre de la mission

Objectifs

- Proposer une charte de gouvernance destinée au Comité de Direction.
- Définir précisément le rôle du futur RSSI de LiZbiZ.
- Mettre en place une matrice RACI pour la gestion des incidents critiques.
- Formuler des recommandations opérationnelles immédiatement applicables.

2 CHARTE DE GOUVERNANCE PROPOSÉE

2.1 Structure de gouvernance cible

La charte proposée repose sur trois instances complémentaires dont les attributions sont clairement séparées pour éviter tout conflit d'intérêt.

Le **Comité Exécutif** (COMEX), composé du PDG, du DAF et de la DSI, est l'instance de décision stratégique. Il valide les budgets de sécurité, arbitre les risques acceptés et définit les orientations politiques de haut niveau.

Le **Comité de Sécurité** (CS), animé par le RSSI et réunissant le DSI, des représentants métiers et le DPO, est l'instance opérationnelle mensuelle. Il assure le suivi des incidents, l'avancement des chantiers de sécurité et la gestion des non-conformités.

Le **RSSI**, rattaché directement à la Direction Générale et indépendant de la DSI, est le garant au quotidien de la politique de sécurité.

2.2 Fiche de poste du RSSI de LiZbiZ

Définition

Intitulé du poste : Responsable de la Sécurité des Systèmes d'Information – LiZbiZ

Rattachement hiérarchique : Direction Générale (PDG)

Positionnement : Indépendant de la DSI pour garantir la séparation des pouvoirs entre construction du SI et contrôle de sa sécurité.

Les missions permanentes du RSSI sont les suivantes. Sur le plan stratégique, il élabore et maintient la Politique de Sécurité des Systèmes d'Information (PSSI), pilote la cartographie des risques et présente un tableau de bord trimestriel au COMEX.

Sur le plan opérationnel, il supervise la gestion des accès (création, modification, révocation), valide les projets techniques à fort impact sur la sécurité, coordonne les audits internes et externes, et pilote les exercices de simulation de crise.

Sur le plan humain, il conduit les campagnes de sensibilisation des collaborateurs,

notamment contre le phishing, et veille à la signature et au respect de la charte informatique par l'ensemble des employés.

Information

Profil recherché : Bac+5 en sécurité de l'information ou gestion des SI. Certifications souhaitées : CISSP, CISM ou équivalent. Expérience de 5 ans minimum dans un poste similaire. Bonne capacité à communiquer avec des interlocuteurs non techniques (COMEX, métiers).

2.3 Matrice RACI pour la gestion des incidents critiques

La matrice ci-dessous formalise les rôles de chaque acteur lors des cinq phases de traitement d'un incident de sécurité critique chez LiZbiZ. Elle s'applique à tout incident de niveau 4 (critique) ou 5 (catastrophique) sur l'échelle de gravité interne.

Phase	PDG	DSI	RSSI	Equipe Tech.	DPO	Dir. Métier
Détection et qualification	I	C	A	R	I	I
Confinement de l'incident	I	C	A	R	I	I
Communication de crise	A	C	R	I	C	R
Éradication et restauration	I	A	C	R	I	I
RETEX et plan d'actions	I	C	A	R	C	C

Table 2.1 – Matrice RACI – Gestion des incidents critiques chez LiZbiZ

À retenir

Lecture de la matrice : pour chaque phase, un seul acteur porte la redevabilité (A). Le RSSI est Accountable sur la détection, le confinement et le RETEX, car ce sont des décisions de sécurité. Le PDG est Accountable sur la communication de crise, car il est le porte-parole légal de l'entreprise cotée en bourse.

3 RECOMMANDATIONS ET PLAN DE MISE EN OEUVRE

3.1 Actions prioritaires

Objectifs

- **Immédiat (0 à 30 jours) :** Recruter ou nommer un RSSI intérimaire. Formaliser la charte informatique et la faire signer par l'ensemble des collaborateurs.
- **Court terme (1 à 3 mois) :** Constituer le Comité de Sécurité et tenir la première réunion. Auditer les comptes Active Directory pour identifier les accès orphelins (anciens collaborateurs encore actifs).
- **Moyen terme (3 à 6 mois) :** Déployer un processus de gestion des accès basé sur le principe du **moindre privilège**. Élaborer la PSSI formelle et la soumettre au COMEX pour validation.

3.2 Indicateurs de suivi

Pour évaluer l'efficacité de la charte, les indicateurs clés suivants sont proposés au Comité de Sécurité.

Indicateur	Cible	Frequence
Nombre de comptes orphelins actifs	0	Mensuelle
Délai moyen de qualification incident	Moins de 1h	Mensuelle
Taux de couverture formations sécur.	100%	Trimestrielle
Incidents de niveau critique ou plus	Moins de 2	Trimestrielle
Audit interne réalisé	1 par an	Annuelle

TABLE 3.1 – Tableau de bord sécurité proposé pour LiZbiZ

3.3 Risques résiduels et limites de la charte

La présente charte constitue un cadre de gouvernance de premier niveau. Elle ne se substitue pas à une analyse de risque exhaustive selon la méthode EBIOS RM, ni à un audit de conformité ISO 27001. Ces étapes restent à planifier dans le cadre de la mission globale des consultants.

Attention

Sans l'engagement explicite de la Direction Générale et l'allocation d'un budget dédié, toute charte de gouvernance reste un document sans portée réelle. La condition sine qua non de son efficacité est la volonté politique du PDG de Jean-Pierre L. de placer la cybersécurité au rang des priorités stratégiques de LiZbiZ.

4 CONCLUSION

La situation de LiZbiZ illustre un écart classique entre la croissance opérationnelle d'une entreprise et la maturité de sa gouvernance de la sécurité. Le cumul des fonctions DSI et RSSI, l'absence de comité de sécurité et l'inexistence de processus formalisés exposent l'entreprise à des risques significatifs, particulièrement dans un contexte où la menace Ransomware vise en priorité les acteurs du e-commerce.

La charte proposée répond directement à la demande du Comité de Direction en établissant des responsabilités claires, en définissant le périmètre du futur RSSI et en formalisant les rôles de chacun via la matrice RACI. Elle constitue la fondation sur laquelle pourront s'appuyer les travaux ultérieurs : analyse de risque, audit ISO 27001 et mise en oeuvre du Plan de Continuité d'Activité.